

Project Report — AuthShield 360 v2

Adaptive Identity-Defense Platform (Risk-Based Authentication), Enterprise/Education Edition

Project	AuthShield 360 — adaptive authentication with a live 0–100 risk score and real-time SOC monitoring
Version	v2 (Real-Time Enterprise Edition)
Reference	TechWiz 7 SRS «Ethical Cyber Horizons» (extract: <code>../reference/srs-extracted.txt</code>)
Stack	Node ≥ 24 (built-in <code>node:sqlite</code>) · Express · SQLite · Nodemailer/Ethereal · Vanilla SPA · SSE
Report date	2026-09-26

1) Overview

AuthShield 360 is a fully local, offline-ready authentication platform implementing the mandated Risk-Based Authentication methodology. Every sign-in attempt is scored on an adaptive **0–100 risk engine with explained reasons**, then routed by band:

- **LOW (0–30):** direct sign-in (Scenario 1) or OTP step-up on demand (Scenario 2/3).
- **MEDIUM (31–69): Cross-Device Approval** (Apple/Google style) with e-mail + OTP fallback.
- **HIGH (70–100):** immediate account lock-down + administrator alert.

v2 adds four major capabilities: a **school portal with strict RBAC, account recovery / MFA reset**, a **digital-forensics dashboard** that reconstructs chronological event timelines, and an **authentication-performance benchmark** measured from real `elapsed_ms` audit telemetry.

2) What shipped in v2

Component	Details
 Code restructure	Clean separation: <code>frontend/</code> (SPA) fully decoupled from <code>backend/</code> (services + routes). Versioned DB migrations <code>m001</code> (school / recovery / forensics) + <code>m002</code> (forensics indexes) + <code>scenario</code> / <code>elapsed_ms</code> columns on the audit trail.
 New front-end	Modular vanilla SPA (<code>js/{api,soc,user,portal,forensics,app}.js</code>) — top app bar, tabs, portal cards, forensics drawer, access matrix, responsive layout, toasts, cross-device approval modal.
 School portal + RBAC	Modules (Courses / Grades / Assignments / Attendance / Rosters / User directory) gated per role via <code>portalGate(roles)</code> ; 8×3 access matrix rendered for the administrator.
 Account recovery / MFA	<code>request</code> → <code>reset</code> → <code>validate</code> : 6-digit verify code, TOTP + password rotation, 10 single-use recovery codes, every step persisted to the audit trail.

Component	Details
reset	
 Digital forensics	Chronological timeline reconstruction filtered by user / IP / device / outcome; opening a case auto-captures evidence; exports a Markdown evidence report; search, close, delete.
 Authentication performance	Scenario 1/2/3 compared from the real audit trail (<code>elapsed_ms</code>): attempts, average login time, success / failure counters.
 Demo video	<code>demo.mp4</code> regenerated, covering every stage: register → verify → STEP_UP → student portal → admin portal (matrix) → forensics → case → attacks A/B/C → blacklist.

3) Architecture

```
E:\AuthShield360
├─ backend/
│   │   # service layer (fully decoupled from the UI)
│   ├── index.js           # Express boot + static SPA + fallback
│   ├── config.js          # risk weights / bands / policies / GEO_TABLE (AS360_DB_PATH overridable)
│   └── db.js              # node:sqlite – schema + seed + DAOs
├─ (audit/factor/session/device/portal/recovery/case)
│   ├── auth.js            # register/verify/trust/risk orchestration/cross-approval/RBAC/recovery
│   ├── risk-engine.js     # 0-100 {score, level, reasons[]}
│   ├── network.js · totp.js · cookie.js · mailer.js · console.js
│   ├── portal.js · forensics.js · benchmark.js
│   └── routes.js          # single router under /api (REST + SSE)
├─ frontend/
│   │   # SPA
│   ├── index.html         # view-ingest + view-app (tabs) + approval modal + toasts
│   ├── js/{api,soc,user,portal,forensics,app}.js
│   └── css/styles.css
├─ scripts/
│   ├── smoke.js           # 17 checks (no server)
│   ├── e2e-all.js         # 77 checks against a live server
│   ├── ui-smoke.js        # 28 UI checks via real browser (puppeteer-core)
│   ├── restart-check.js   # 18 NFR checks – data survives process restart
│   ├── record-demo.js     # regenerates demo.mp4
│   └── reset-db.js        # wipe + reseed
├─ docs/technical/
│   │   # bilingual deliverables + role matrix
└─ demo.mp4
```

Sign-in flow: browser fingerprint `SHA-256` → `X-FP` (+ encrypted `as360_trust` cookie once trusted) → password → network / geo / travel analysis → `evaluateRisk()` → band decision → every branch committed to `audit_trail` and broadcast over SSE to the SOC feed.

4) Security: factors & bands

Factor	Weight	Note
F_TIME_ANOMALY (outside 07:00–23:00)	+15	
F_NEW_IP (unseen subnet)	+25	

Factor	Weight	Note
F_NEW_DEVICE (unknown fingerprint) alone	+30	alone = LOW
F_UNRECOGNIZED_DEVICE	+30	
F_CONSECUTIVE_FAILURE	+20/attempt	2nd ⇒ +40
F_IMPOSSIBLE_TRAVEL (> 1,000 km/min)	+40	Haversine via GEO_TABLE
F_BLACKLISTED_IP	+45	
Clamped	0–100	LOW / MEDIUM / HIGH

- **Hardening:** SHA-256 + pepper passwords (demo-grade), random session tokens, RFC 6238 TOTP with expiry-aware validation, AES-256-GCM 1-year trust cookie that users can revoke.
- **Smart logout:** 2 wrong passwords ⇒ lock (no account-enumeration oracle; unknown identities get deferred failures); invalid OTP never locks the account.
- **RBAC:** Scenario 3 from a STUDENT becomes `HIGH_RISK_BLOCK (UNAUTHORIZED_ROUTE)`; the school portal enforces role gates server-side (403).

5) School portal — role access matrix (3 roles × 8 modules)

Module	STUDENT	TEACHER	ADMINISTRATOR
Courses	✓	✓	✓
Grades / Exam results	✓ own	✓ own courses	✓ all
Assignments	✓ enrolled	✓ own courses	✓ all
Attendance	✓	✓	✓
Class rosters	✗ 403	✓ own courses	✓ all
User directory	✗ 403	✗ 403	✓
SOC monitoring	✗ 403	✗ 403	✓
Forensic investigations	✗ 403	✗ 403	✓

Full matrix: `User_and_Role_Access_Matrix.md`.

6) Recovery, forensics & performance

Account recovery / MFA reset `POST /api/recovery/request` (identifier → 6-digit verify code) → `POST /api/recovery/reset` (rotate TOTP + change password + issue 10 single-use recovery codes) → `POST /api/recovery/validate` (code consumed once). Persisted as `RECOVERY_REQUEST` / `RECOVERY_RESET` / `RECOVERY_CODE_VALID` plus a security alert.

Digital forensics `/api/forensics/{summary,entities,timeline,cases}` — the timeline re-links audit events (`ref` + kind + ts) scoped by user / IP / device / outcome; opening a case auto-captures matching evidence; **Markdown export** produces an archivable evidence report.

Benchmark `/api/benchmark` reads real `elapsed_ms` from the audit trail and compares scenarios 1/2/3: attempts, average login time, success/failure/block counters.

7) Test strategy & evidence

Suite	Tool	Result	Covers
Smoke	<code>scripts/smoke.js</code>	17/17	risk engine (weights/bands/reasons), S1/S2/S3, lockout, register→verify→trusted device
Full E2E	<code>scripts/e2e-all.js</code>	77/77	all scenarios + cross-device approval + lists + attacks A/B/C + SSE + portal RBAC (3 roles) + recovery + forensics + benchmark
UI	<code>scripts/ui-smoke.js</code>	28/28	browser tour: auth, tabs, portal, matrix, forensics, benchmark, security center, logout
NFR	<code>scripts/restart-check.js</code>	18/18	users/sessions/devices/audit/cases/attacks survive a hard process restart on the same DB

Total: 140 checks green on a pristine DB (kill → `reset-db` → start → run full suite).

Development-log notes: on a pristine DB every device/subnet is unrecognized, so the E2E suite automatically walks the **approval chain** (approve→finalize) — harder and more honest. A real bug was found and fixed along the way: `courseRosters` passed `null` to a parameter-less query for ADMIN → "column index out of range" (admin portal now works).

8) Demo credentials

Username	Password	Role
<code>admin</code>	<code>Admin@123</code>	ADMINISTRATOR (SOC / portal / forensics / benchmark)
<code>student1</code> · <code>student2</code>	<code>Student@123</code>	STUDENT (Security Center + portal)
<code>teacher1</code> · <code>teacher2</code>	<code>Teacher@123</code>	TEACHER (portal + rosters)

The login screen’s **DEMO panel** streams the live TOTP for every account (refreshes every 30 s).

9) Deliverables

File	Description
Technical_Report_AR.md · Technical_Report_EN.md	this bilingual report
User_and_Role_Access_Matrix.md	8×3 role matrix
Identity_Security_Test_Matrix.md / .json	reproducible security-test matrix with evidence refs
../reference/WORKFLOW.md	full technical workflow
docs/01-دليل التشغيل والاستخدام.md	Arabic non-technical guide
presentation/index.html	Arabic presentation
demo.mp4	live screen-recording of every stage and feature
scripts/*	complete automation (140 checks)

10) Notes & disclaimer

Educational / demonstration platform — not a substitute for a validated Identity Provider (Auth0, Keycloak, Entra ID) in production. Passwords are demo-grade (SHA-256 + pepper); swap for argon2/scrypt in production.